Auditoría de usabilidad y seguridad

Web de la AFA del CEIP Padre Poveda · three-growth.localsite.io · 28 de octubre de 2026

Alcance. Revisión de la portada, la navegación, los formularios de contacto, la vista móvil (390 px) y la superficie expuesta de WordPress. Todo fueron peticiones de lectura: no se enviaron formularios ni se intentó iniciar sesión.

Contexto. La web se sirve desde un enlace público de Local (entorno de desarrollo de WordPress). Los hallazgos de servidor (Apache, cabeceras) pueden no coincidir con producción. Los de contenido, enlaces, RGPD y configuración de WordPress casi seguro que sí. Durante la preparación de este informe el enlace dejó de responder con la web, devolviendo un “404” en blanco para todas las URLs, así que algunas capturas se tomaron antes.

Lo urgente. Los puntos 1 a 5 se arreglan en una o dos horas y hoy están rompiendo la captación de socios y el cumplimiento legal: el botón “Hazte socio” y las páginas legales dan 404, Microsoft Clarity graba sesiones sin consentimiento y el formulario pide aceptar una política de privacidad que no existe.

Hallazgos por prioridad

#	Prioridad	Tipo	Hallazgo	Evidencia	Recomendación
1	Crítica	Usabilidad / Conversión	**El botón principal “Hazte socio” lleva a una página que no existe (404)**	/hazte-socio/ → 404. Enlazado desde la cabecera, el menú AFA y el bloque “Hazte Socio Ahora”	Crear la página o redirigir a la correcta. Es el objetivo número uno de la web
2	Crítica	Legal (RGPD/LSSI)	**No existen Aviso legal, Privacidad ni Cookies**	Los tres enlaces del pie dan 404	Publicar las tres páginas: obligatorio para una asociación que recoge datos
3	Crítica	Legal / Privacidad	**Microsoft Clarity (grabación de sesiones y mapas de calor) se carga sin banner de consentimiento, en una web de familias con menores**	Se cargan clarity.ms/tag/… y clarity.js. No hay CMP ni ningún elemento de consentimiento	Bloquear Clarity hasta el consentimiento (o quitarlo), enmascarar formularios y declararlo en la política de cookies
4	Alta	Legal (RGPD)	**El formulario de contacto pide aceptar una política de privacidad que no está enlazada (y no existe) y no da la información básica (responsable, finalidad, legitimación, derechos)**	2 formularios (/contacto-afa/ y /ampa-3/contacto/). El checkbox no tiene enlace	Enlazar la política y añadir la “primera capa” informativa bajo el formulario
5	Alta	Usabilidad	**Otros 4 enlaces rotos en la portada**	Comedor → /servicios/comedor/; Calendario → /calendario/; Voluntarios → /afa/; “Contactar con Vocalías” → /contacto/. Los cuatro dan 404 (las páginas reales existen con otra URL)	Corregir URLs o crear redirecciones 301. Añadir un comprobador de enlaces rotos
6	Alta	Seguridad	**XML-RPC activo con system.multicall: permite probar cientos de contraseñas en una sola petición**	POST /xmlrpc.php → 200 y lista de métodos con system.multicall	Desactivar XML-RPC salvo que lo use la app de Jetpack
7	Alta	Seguridad / SEO	**El entorno de desarrollo es público e indexable (canonical a localsite.io) y Clarity también está activo aquí**	Meta robots max-image-preview:large y sitemap público	Proteger con contraseña o noindex, quitar la analítica del staging y cerrar el live link cuando no se use
8	Alta	Seguridad	**Se pueden enumerar los usuarios**	/wp-json/wp/v2/users devuelve 7 usuarios y /wp-sitemap-users-1.xml está expuesto. Al menos un slug coincide con el nombre visible	Restringir el endpoint users a usuarios autenticados, quitar los usuarios del sitemap y usar logins distintos del nombre público
9	Alta	Seguridad	**wp-login.php está accesible sin protección visible**	200 en /wp-login.php (no se probó el límite de intentos)	2FA obligatorio para los 7 usuarios, límite de intentos y, si es posible, restringir el login

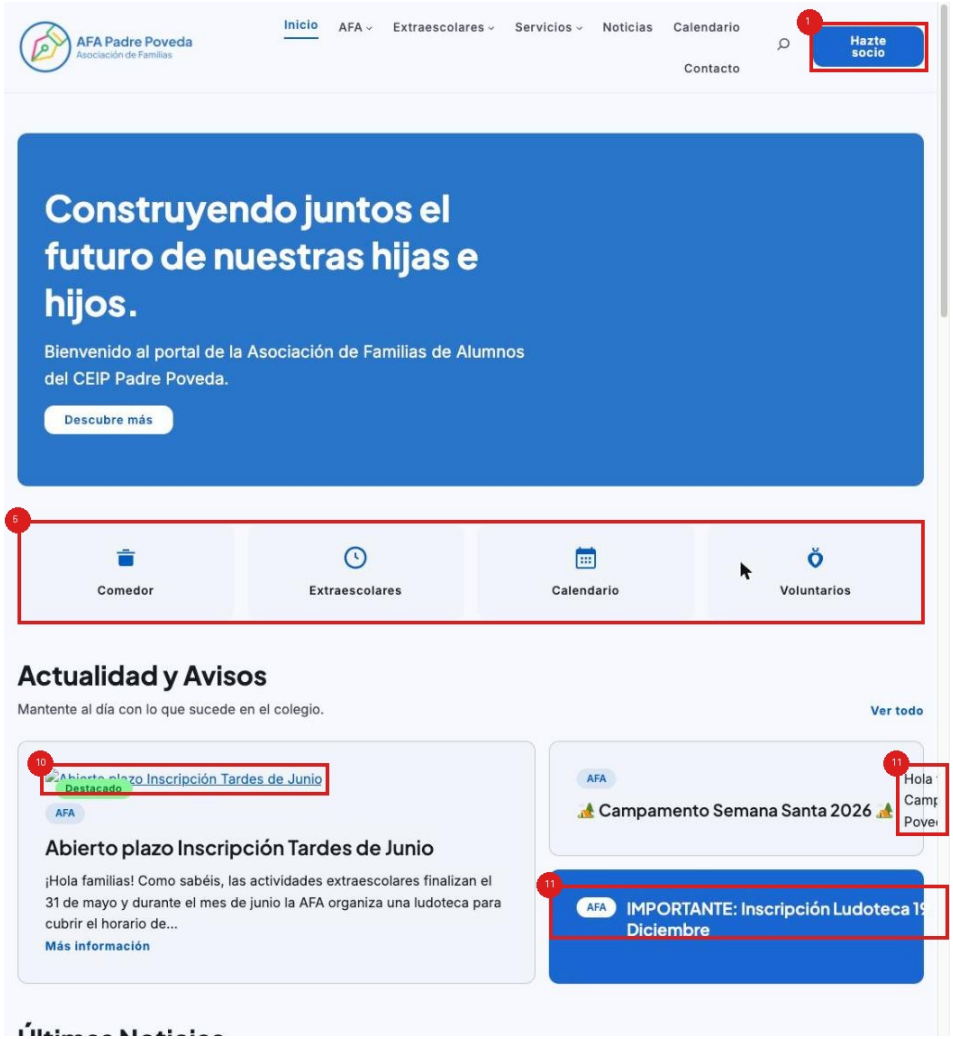
#	Prioridad	Tipo	Hallazgo	Evidencia	Recomendación
10	Media-alta	UX / Visual	**La portada se ve rota: 4 de 14 imágenes no cargan y las tarjetas de noticias miden unos 2.000 px de alto, casi todo en blanco**	Imágenes de /uploads/2026/04-05/ sin cargar. Una imagen rota se pinta con 1.688 px de alto y aparece el texto alt subrayado	Volver a subir los medios (parece una migración incompleta), aspect-ratio/object-fit y placeholder CSS
11	Media-alta	UX / Visual	**El texto se sale de las tarjetas: los títulos y extractos de los avisos secundarios desbordan el contenedor por la derecha**	Capturas de escritorio	overflow:hidden, min-width:0 en los hijos del grid y line-clamp en los extractos
12	Media	Contenido	**“Actualidad y Avisos” está desactualizado: a 28/10/2026 muestra la inscripción de junio, Semana Santa 2026 y la ludoteca de diciembre de 2025. La última noticia es de abril**	Fechas de los posts	Ocultar automáticamente los avisos caducados (fecha de expiración) y priorizar el curso 2026/27
13	Media	Seguridad	**Faltan cabeceras de seguridad**	Sin CSP, X-Frame-Options/frame-ancestors, X-Content-Type-Options ni Referrer-Policy. Se comprobó que la web se puede cargar dentro de un iframe (clickjacking)	frame-ancestors 'self', nosniff, strict-origin-when-cross-origin y una CSP básica
14	Media	Seguridad	**Se exponen versiones del software**	Generator WordPress 7.1.3, Server Apache/2.4.43, X-Powered-By PHP/8.5.3, readme.html y readme.txt de los plugins (WPVR 9.3.1, The Events Calendar 6.18.2)	Ocultar las cabeceras y el generator, bloquear los readme y revisar las versiones en WPScan. Si producción usa Apache 2.4.43 (de 2020), actualizarlo
15	Media	Seguridad	**Plugin WPVR (tours virtuales) instalado**	Se cargan assets de /plugins/wpvr/	Si no se usa, desinstalarlo. Si se usa, mantenerlo siempre actualizado
16	Media	Usabilidad	**Iconos de Instagram y Facebook sin destino**	href="#"	Enlazar los perfiles reales o quitar los iconos
17	Media	Arquitectura de información	**Contenido duplicado u obsoleto**	2 páginas de contacto y 2 de extraescolares. “Trueque” sigue en el menú aunque se sustituyó en 2019/20	Consolidar con 301 y retirar Trueque del menú
18	Media	Coherencia / SEO	**Mezcla de “AMPA” y “AFA” y URLs poco limpias**	/ampa-3/, /servicios-del-ampa/, autor “Junta Ampa…”, un post con slug /2026/05/8622/ y slugs con emojis codificados	Unificar en “AFA”, limpiar los slugs con 301 y quitar los emojis de títulos y URLs
19	Baja	Usabilidad móvil	**El menú móvil está totalmente desplegado y alineado a la derecha, sin jerarquía visual. “Hazte socio” queda enterrado**	Captura a 390 px	Acordeones por sección, alineación a la izquierda y CTA fijo arriba
20	Baja	Usabilidad	**“Ver todo” (Avisos) y “Ver noticias” llevan a la misma página**	Ambos → /noticias/	Separar por categoría (/category/avisos/) o fusionar los bloques
21	Baja	SEO / Social	**Metadatos pobres**	og:title=Inicio, og:description genérica, sin meta description y el <title> repite el nombre dos veces	Configurar Yoast o Rank Math con descripción, imagen OG y título limpio
22	Baja	Rendimiento	**Peso innecesario**	Se carga wp-emoji-release.min.js y el menú usa enlaces http:// que obligan a una redirección extra	Desactivar los emojis de WP y convertir los enlaces a relativos o https

Lo que está bien: el buscador escapa bien la entrada (no se encontró XSS reflejado), los formularios usan honeypot oculto a lectores de pantalla y un token de sesión, el listado de /uploads/ está bloqueado (403), no hay .env, .git ni debug.log expuestos, hay HSTS y todas las imágenes tienen alt.

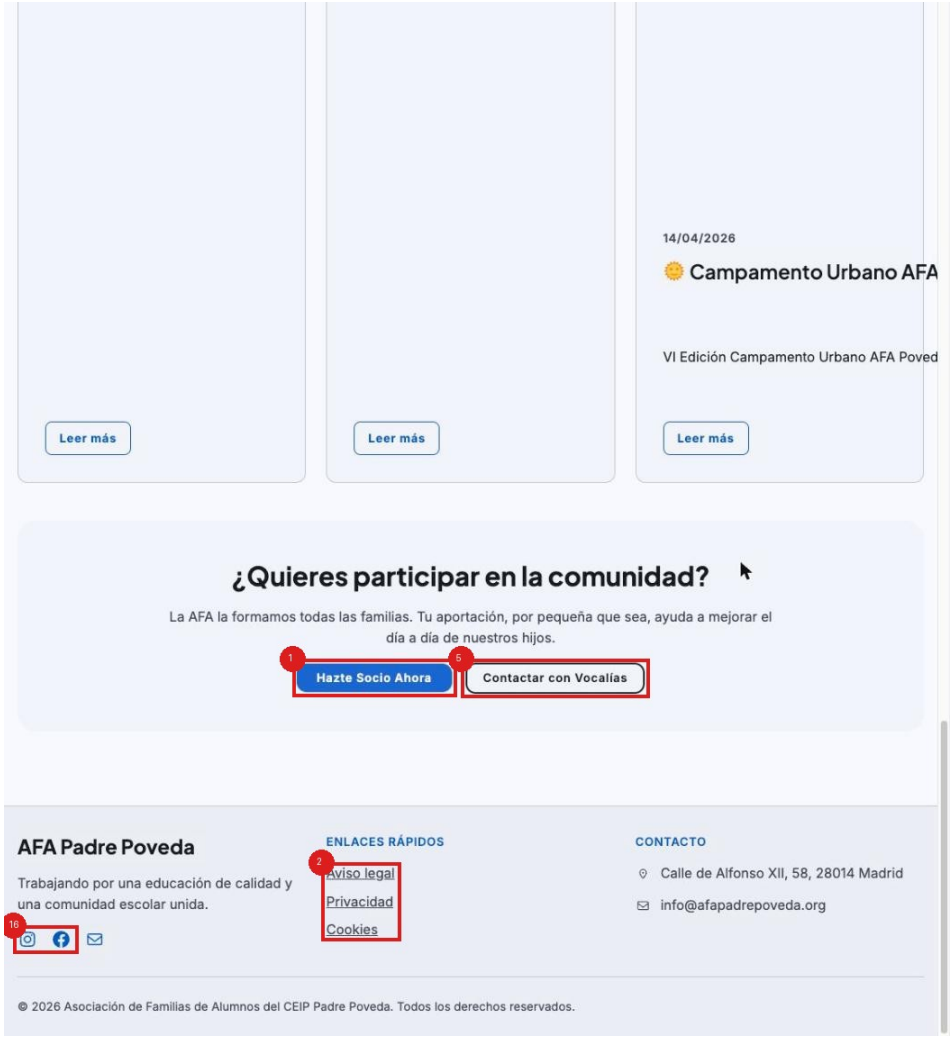
No verificado: el límite de intentos en el login, el envío real de los formularios y las vulnerabilidades concretas de las versiones de los plugins (conviene pasarlo por WPScan).

Capturas · Escritorio

Los números en rojo remiten a los hallazgos de la tabla.

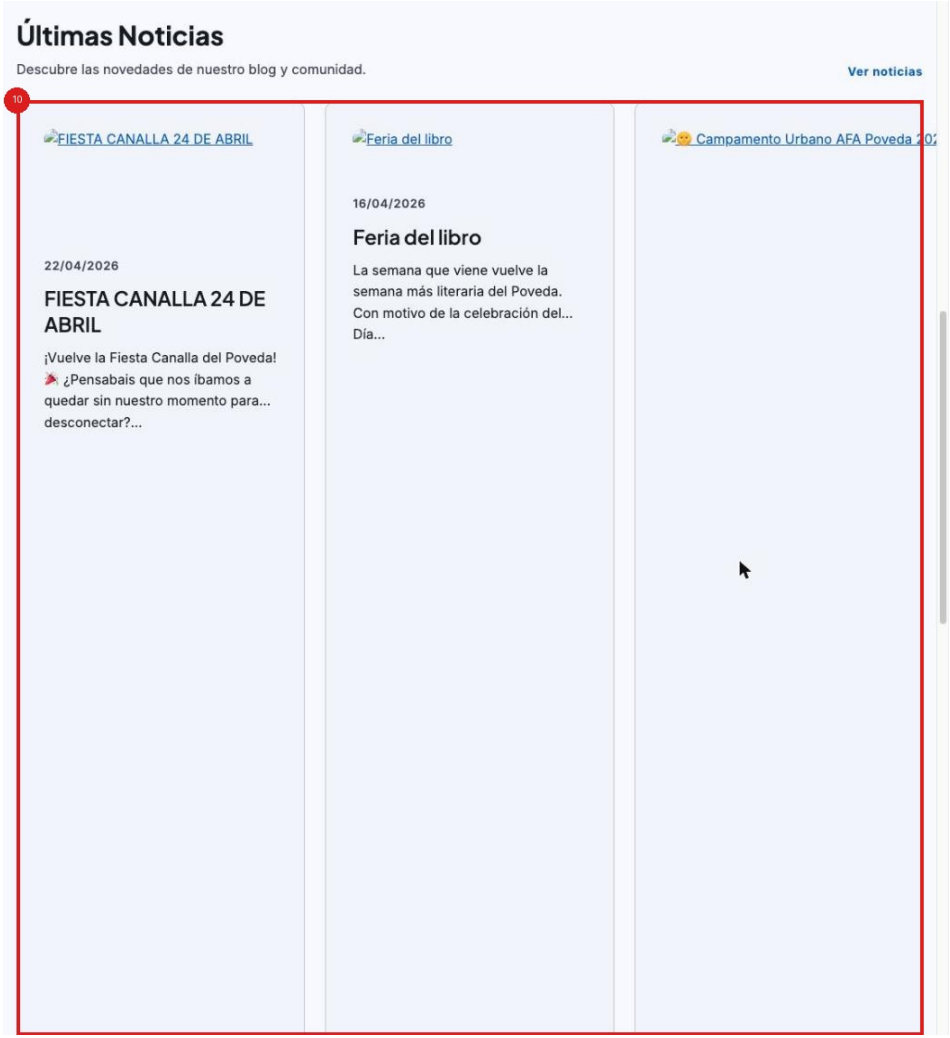


Portada. (1) “Hazte socio” lleva a un 404. (5) Accesos rápidos rotos: Comedor, Calendario y Voluntarios. (10) Imagen destacada rota con el texto alt visible. (11) Títulos y extractos que se salen de las tarjetas.



Bloque final y pie. (1) “Hazte Socio Ahora” y (5) “Contactar con Vocalías” llevan a un 404. (2) Aviso legal, Privacidad y Cookies dan 404. (16) Instagram y Facebook enlazan a “#”.

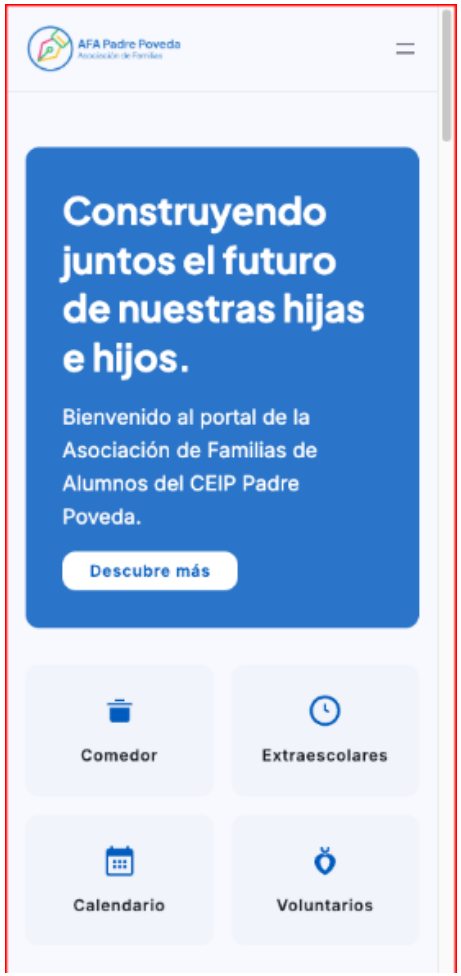
Capturas · Tarjetas de noticias (escritorio)



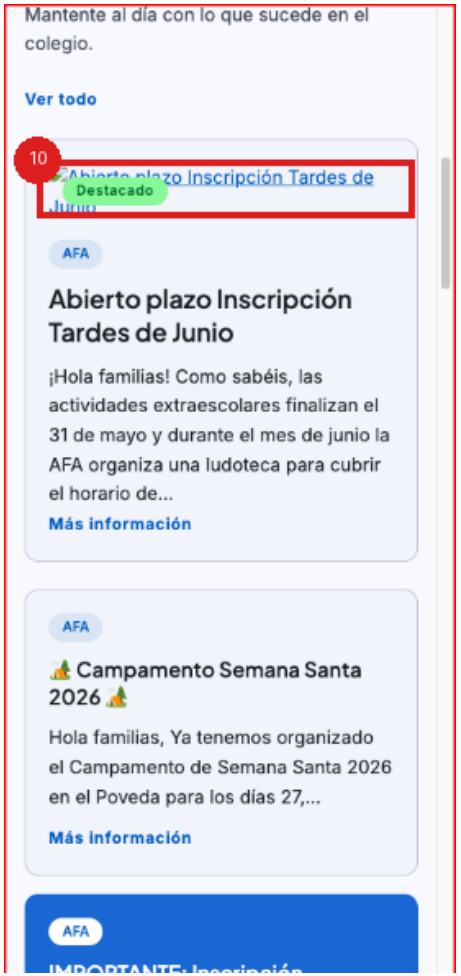
(10) Las imágenes de las tres noticias no cargan. Una imagen rota se pinta con 1.688 px de alto, así que cada tarjeta mide unos 2.000 px. El usuario ve una gran zona en blanco y el título de la tercera noticia aparece muy abajo, desbordando además por la derecha (11).

Causa probable: medios de /uploads/2026/04 y /05 no migrados al entorno, sin aspect-ratio ni object-fit en las imágenes de las tarjetas.

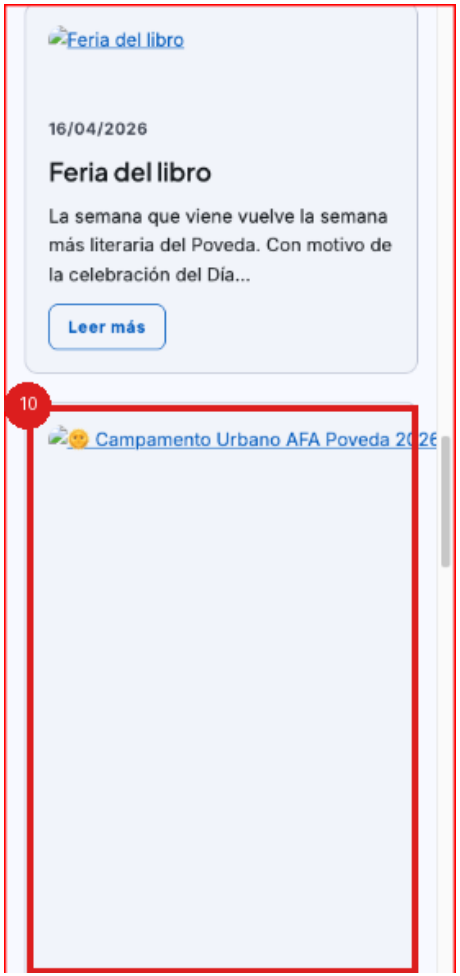
Capturas · Móvil (390 px)



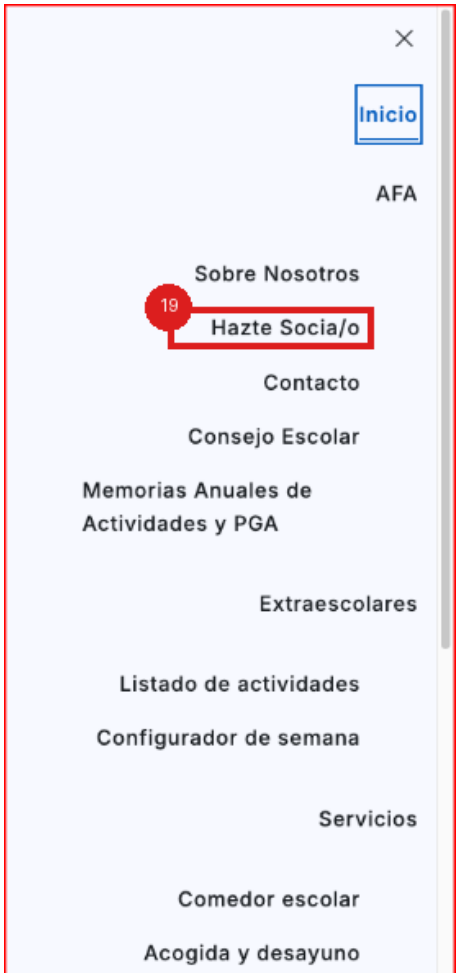
Portada: el hero y los accesos se ven bien (aunque 3 de los 4 accesos dan 404).



(10) Imagen destacada rota con el alt visible y solapada con la etiqueta “Destacado”.



(10) La tarjeta de noticia con la imagen rota queda casi entera en blanco.



(19) El menú móvil está totalmente desplegado y alineado a la derecha, y “Hazte socio” queda enterrado.